

Clase 187 — Detección basada en MITRE ATT&CK

Parte: 8 — Blue Team, detección y SOC · Fuente: MITRE ATT&CK — framework de tácticas y técnicas adversarias 🕒 Duración estimada: 110 min · Nivel: Intermedio

🎯 Objetivo

Usar MITRE ATT&CK como columna vertebral de la detección: hablar de comportamiento adversario con un vocabulario común, mapear tus detecciones a técnicas, medir cobertura con ATT&CK Navigator y priorizar qué detectar usando la pirámide del dolor. Dejarás de perseguir IOCs volátiles para detectar TTPs (tácticas, técnicas y procedimientos) que al atacante le duele cambiar.

📊 Resultados de aprendizaje

Al finalizar, el alumno podrá:

- 1. **Navegar** la matriz ATT&CK (tácticas, técnicas, subtécnicas) y su terminología.
- 2. **Mapear** detecciones y fuentes de datos a técnicas concretas.
- 3. **Visualizar** cobertura y huecos con ATT&CK Navigator.
- 4. **Priorizar** detecciones con la pirámide del dolor de David Bianco.
- 5. **Usar** los data sources de ATT&CK para saber qué telemetría requiere cada técnica.

📖 Temas

#	Tema	Por qué importa
1	Estructura de ATT&CK	Vocabulario común de ataque
2	Tácticas vs técnicas vs procedimientos	Distintos niveles de abstracción
3	Pirámide del dolor	Qué detectar primero y por qué
4	Data sources y componentes	Qué log necesita cada técnica
5	ATT&CK Navigator	Mapa de cobertura y priorización
6	Detecciones por técnica	Del framework a reglas reales
7	Grupos y software (intel)	Amenazas relevantes para tu sector
8	Cobertura vs profundidad	No basta con "tocar" cada técnica

📖 Definiciones y características

- **Táctica:** el "por qué" del adversario (Ejecución, Persistencia, Exfiltración). Característica: 14 categorías que forman las columnas de la matriz.
- **Técnica:** el "cómo" (T1059 Command and Scripting Interpreter). Característica: puede tener subtécnicas (T1059.001 PowerShell).

- **Procedimiento:** la implementación concreta que usa un grupo. Característica: el nivel más específico y variable.
- **Pirámide del dolor:** modelo que ordena los indicadores por lo difícil que es para el atacante cambiarlos (hash < IP < dominio < artefactos < herramientas < TTPs). Característica: detectar arriba de la pirámide causa más "dolor".
- **Data source (ATT&CK):** tipo de telemetría necesaria para detectar una técnica (Process Creation, Network Traffic). Característica: guía tu estrategia de logging.
- **ATT&CK Navigator:** herramienta web para colorear la matriz según cobertura o intel. Característica: comunica huecos visualmente.

Herramientas y preparación

- **ATT&CK Navigator** (versión web oficial o desplegada localmente).
- El **STIX/JSON de ATT&CK** para automatizar mapeos si lo deseas.
- Tus reglas Sigma de la clase 186 (ya traen tags `attack.tXXXX`).
- **DeTT&CT** o **Atomic Red Team** para razonar sobre cobertura y validación (Atomic se usará en profundidad en la clase 200).

Cualquier ejecución de técnicas para validar se hace en el laboratorio propio.

Laboratorio guiado — Mapa de cobertura de detección

1. **Inventaria tus detecciones.** Lista tus reglas Sigma/SIEM y anota el `attack.tXXXX` de cada una.
2. **Carga Navigator.** Abre ATT&CK Navigator y crea una capa nueva.
3. **Colorea cobertura.** Marca en verde las técnicas que tus reglas cubren; en rojo las críticas sin cobertura.
4. **Cruza con tus fuentes.** Para 5 técnicas rojas, revisa su *data source* en ATT&CK y verifica si ya recolectas esa telemetría (clase 182).
5. **Aplica la pirámide del dolor.** Clasifica 10 de tus detecciones: ¿detectas por hash/IP (base) o por comportamiento/TTP (cima)? Prioriza subir de nivel.
6. **Prioriza con intel.** Elige un grupo relevante para tu sector (p. ej. de la página de Groups de ATT&CK) y superpón sus técnicas: cubre primero las que ese grupo usa.
7. **Documenta huecos.** Genera un plan: 5 técnicas sin cobertura, la telemetría que faltaría y la detección propuesta.

Ejercicios

1. Clasifica 6 indicadores en su nivel de la pirámide del dolor.
2. Elige una técnica (p. ej. T1053 Scheduled Task) y lista su data source y una detección.
3. Crea una capa de Navigator con la cobertura real de tu laboratorio.
4. Explica por qué detectar por hash es frágil con un ejemplo concreto.
5. Mapea un ataque de la Parte 7 (red team) a una cadena de técnicas ATT&CK.
6. Propón cómo pasarías una detección de nivel IP a nivel TTP.

Reto verificable

Entrega una capa de ATT&CK Navigator que refleje la cobertura de detección de tu laboratorio y un plan priorizado de 5 huecos a cerrar, cada uno con su data source y detección propuesta. **Criterio de**

aceptación: la capa distingue claramente técnicas cubiertas y no cubiertas, y para cada hueco justificas la prioridad usando la pirámide del dolor y/o la relevancia de un grupo de amenaza concreto.

⚠ Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
"Cubrimos el 90% de ATT&CK"	Confundes tocar la técnica con detectarla bien; mide profundidad, no solo presencia
Detecciones solo por IOC	Estás en la base de la pirámide; migra a comportamiento
Técnica marcada verde sin telemetría	No hay data source que la respalde; revisa fuentes reales
Navigator saturado de colores	Falta priorización; filtra por intel relevante
Subtécnicas ignoradas	Mapeas solo a la técnica padre; baja al nivel de subtécnica

? Preguntas frecuentes

? **¿Debo intentar cubrir toda la matriz?** No. Prioriza por amenazas reales de tu sector y por profundidad. Cien técnicas mal cubiertas valen menos que veinte detectadas con solidez.

? **¿ATT&CK sustituye a la Cyber Kill Chain?** No compiten. La Kill Chain describe fases de alto nivel; ATT&CK detalla el "cómo" con técnicas concretas. Muchos equipos usan ambas.

? **¿Cobertura de Navigator = seguridad?** Es un mapa, no una garantía. Una técnica en verde puede tener una regla frágil o llena de falsos positivos. Valídala (clase 200, purple team).

🔗 Referencias

- MITRE ATT&CK — <https://attack.mitre.org/>
- ATT&CK Navigator — <https://mitre-attack.github.io/attack-navigator/>
- Bianco, D. "The Pyramid of Pain" — <http://detect-respond.blogspot.com/2013/03/the-pyramid-of-pain.html>
- ATT&CK Data Sources — <https://attack.mitre.org/datasources/>
- DeTT&CT — <https://github.com/rabobank-cdc/DeTT&CT>

➡ Siguiente clase

Clase 188 - Threat hunting: metodología